

CY021 – Best Practices for Secure, Ethical, and Resilient Implementation of Project PHOENIX

1 Introduction

Project PHOENIX operates at the intersection of cybersecurity, emergency management, and community resilience. As demonstrated by recent Australian disaster events, cybercriminals exploit crises through fraudulent donation schemes, misinformation campaigns, and targeted attacks on emergency services. During the 2019–20 Black Summer, Scamwatch reported that “scammers also follow disasters in order to take advantage of the generosity” of donors, with over 500 fraudulent bushfire-related scams circulating. Similarly, the 2022 ransomware attack on Fire Rescue Victoria (FRV) “continues to severely impact” operational systems months after the incident.

These incidents highlight the need for a rigorous best-practice framework to guide the secure, ethical, and resilient development of PHOENIX. This document establishes these best practices, ensuring that PHOENIX aligns with legal requirements, cybersecurity standards, and ethical obligations while supporting the project’s mission to protect Victorian communities during natural disasters.

2 Purpose of have Best Practices

The purpose of this document is to define a comprehensive set of best practices that govern the design, development, deployment, and evaluation of PHOENIX. These practices ensure:

- Security and privacy are embedded throughout the system lifecycle
- Ethical and responsible use of AI and cryptographic technologies
- Operational resilience during disaster conditions
- Trustworthy communication with communities and emergency services
- Compliance with Australian legal and regulatory frameworks

3 Scope

Best Practices applies to:

- All PHOENIX work packages (ADCRS, TEAVS, Blueprint development)
- All team members, researchers, and partner LGAs
- All data processed, transmitted, or stored by PHOENIX

- All technical artefacts, governance documents, and operational procedures

4 Best Practice Domains

4.1 Security-by-Design

Security-by-Design ensures that PHOENIX incorporates robust security controls from inception rather than as an afterthought.

Best Practices

- Implement encryption for all data in transit and at rest.
- Apply role-based access control (RBAC) across ADCRS and TEAVS.
- Conduct periodic vulnerability assessments and penetration testing.
- Store cryptographic keys in secure hardware or cloud-based vaults.
- Maintain secure coding standards aligned with OWASP and ASD Essential Eight.

Justification

The FRV ransomware incident demonstrates the consequences of inadequate security controls in emergency-service systems, reinforcing the need for proactive security integration.

4.2 Privacy-by-Design

Privacy-by-Design ensures compliance with the Privacy Act 1988 and Australian Privacy Principles (APPs).

Best Practices

- Collect only the minimum data required for threat modelling and alert verification.
- Anonymise or pseudonymise data wherever possible.
- Maintain a Data Register documenting all data sources, flows, and retention periods.
- Conduct Privacy Impact Assessments (PIAs) at each major project milestone.
- Ensure TEAVS signatures do not expose personal information.

Justification

Scamwatch evidence shows that disaster victims are frequently targeted; mishandling their data could cause further harm.

4.3 Ethical AI and Responsible Modelling

ADCRS uses AI to correlate hazard data with cyber-threat indicators. Ethical AI practices ensure fairness, transparency, and accountability.

Best Practices

- Maintain human oversight of all AI-generated risk assessments.
- Document model assumptions, training data sources, and limitations.
- Monitor for algorithmic bias and false positives/negatives.
- Ensure explainability of risk scores for council decision-makers.
- Avoid automated public-facing decisions without human validation.

Justification

During the Black Summer, “hundreds of thousands” of misinformation posts circulated, demonstrating the risk of algorithmic amplification of false narratives.

4.4 Operational Resilience and Continuity

PHOENIX must remain functional during disasters and cyber incidents.

Best Practices

- Design TEAVS to operate in low-bandwidth or degraded network conditions.
- Maintain offline fallback procedures for councils and emergency services.
- Conduct resilience testing simulating bushfire and flood scenarios.
- Ensure ADCRS can operate with partial data availability.
- Implement redundancy for critical components.

Justification

The FRV attack forced responders to revert to radios and manual methods, highlighting the need for continuity planning.

4.5 Transparency and Accountability

Trust is essential during emergencies; PHOENIX must operate transparently.

Best Practices

- Publish clear documentation on data use, alert verification, and AI logic.
- Maintain audit logs for all system interactions.
- Provide councils with interpretable explanations of ADCRS outputs.
- Ensure TEAVS verification is publicly accessible and independently verifiable.

Justification

Misinformation undermines public trust; transparency strengthens legitimacy.

4.6 Community-Centred and Inclusive Design

PHOENIX must be accessible to diverse communities, including those with limited digital literacy.

Best Practices

- Use plain language in alerts and public-facing materials.
- Provide multilingual support where feasible.
- Conduct user testing with pilot LGAs and community groups.
- Ensure TEAVS interfaces are intuitive for non-technical staff.
- Consider accessibility standards.

Justification

Disaster-affected communities often experience stress, limited connectivity, and reduced cognitive bandwidth.

4.7 Collaboration and Information Sharing

Cyber resilience requires coordinated action across agencies.

Best Practices

- Integrate Scamwatch, ATO, CERT Australia, and BoM feeds into ADCRS.
- Establish secure communication channels with emergency services.
- Share verified threat intelligence.

- Document lessons learned for inclusion in the Cyber Resilience Blueprint.

Justification

Scam and phishing activity spikes during disasters; timely information sharing reduces harm.

5 Implementation Responsibilities

- Ensuring all best practices are documented, communicated, and reviewed
- Conducting privacy, ethical, and security assessments
- Supporting technical teams in embedding governance requirements
- Maintaining alignment with Victorian emergency-management frameworks
- Ensuring PHOENIX remains ethically and legally compliant throughout its lifecycle

6 Conclusion

This document provides a comprehensive best-practice framework that ensures PHOENIX is secure, ethical, resilient, and community-centred. These practices directly address the vulnerabilities highlighted in recent disasters scams, misinformation, and cyber attacks and support the project's mission to strengthen digital resilience across Victoria.